

# **SGSI-UNCP**

## **Estrategia de Certificación ISO 27001:2022**

Documento Base del Sistema de Gestión  
de Seguridad de la Información

Universidad Nacional del Centro del Perú

# Índice

- 1 Estrategia de Certificación ISO 27001:2022
  - 1.1 Objetivo
  - 1.2 Selección de Entidad Certificadora
  - 1.3 Proceso de Certificación (Fases)
  - 1.4 Preparación Final (Pre-auditoría)
  - 1.5 Recursos Necesarios
  - 1.6 Riesgos Identificados para la Certificación
  - 1.7 Documentos Relacionados

# 1. Estrategia de Certificación ISO 27001:2022

**Organización:** Universidad Nacional del Centro del Perú (UNCP) **Periodo:** 2026-2027 **Responsable:** Oficial de Seguridad y Confianza Digital **Presupuesto Estimado:** S/ 120,000 – 150,000 (auditoría de certificación + pre-auditoría + consultoría de apoyo)

## 1.1. Objetivo

Establecer la hoja de ruta, los criterios de selección de entidad certificadora y las actividades preparatorias necesarias para que la UNCP obtenga la certificación ISO/IEC 27001:2022, demostrando la conformidad de su Sistema de Gestión de Seguridad de la Información.

## 1.2. Selección de Entidad Certificadora

### 1.2.1. Criterios de Selección

| Criterio                                                      | Peso | Descripción                                                                                                                |
|---------------------------------------------------------------|------|----------------------------------------------------------------------------------------------------------------------------|
| <b>Acreditación internacional</b>                             | 25 % | La entidad debe estar acreditada por IAF/DAKKS/ANAB/UKAS. Sin acreditación, el certificado no tiene validez internacional. |
| <b>Presencia en Perú</b>                                      | 20 % | Debe contar con auditores locales o capacidad de despliegue sin costos excesivos de viaje.                                 |
| <b>Experiencia en el sector público/educativo</b>             | 20 % | Experiencia comprobable en certificación de universidades públicas o instituciones del Estado peruano.                     |
| <b>Reputación y reconocimiento</b>                            | 15 % | Reconocimiento en el mercado peruano y latinoamericano.                                                                    |
| <b>Costo total (Etapa 1 + Etapa 2 + 3 años de vigilancia)</b> | 20 % | Relación costo-beneficio del servicio completo.                                                                            |

### 1.2.2. Entidades Certificadoras Recomendadas

| Entidad        | Acreditación | Presencia en Perú          | Experiencia Sector Público                               | Estimado (S/)     | Ventaja Clave                                           |
|----------------|--------------|----------------------------|----------------------------------------------------------|-------------------|---------------------------------------------------------|
| <b>AENOR</b>   | ENAC (IAF)   | Sí, oficina en Lima        | Alta (múltiples municipios y gobiernos regionales)       | 120,000 - 140,000 | Amplia experiencia en el sector público peruano         |
| <b>BSI</b>     | UKAS (IAF)   | Sí, oficina en Lima        | Alta (reconocimiento global, creadores del estándar)     | 130,000 - 150,000 | Prestigio internacional; creadores de ISO 27001         |
| <b>SGS</b>     | ANAB (IAF)   | Sí, oficina en Lima        | Media (más presencia en sector privado)                  | 110,000 - 130,000 | Red global de auditores; buena relación costo-beneficio |
| <b>ICONTEC</b> | ONAC (IAF)   | Sí, representación en Perú | Alta (muy fuerte en educación superior en Latinoamérica) | 100,000 - 120,000 | Mayor experiencia en universidades latinoamericanas     |

### 1.2.3. Proceso de Contratación Recomendado

1. Enviar **solicitud de cotización (RFP)** a las 4 entidades en Q3-2026.
2. Evaluar las propuestas según los criterios de la sección anterior.
3. Solicitar referencias de al menos 2 instituciones similares certificadas por la entidad.
4. Entrevistar al equipo auditor propuesto para la Etapa 1.
5. Seleccionar y contratar en Q4-2026.

## 1.3. Proceso de Certificación (Fases)

### 1.3.1. Cronograma General

| Fase                 | Actividad                                                 | Fecha Sugerida   | Duración Estimada    | Responsable                               |
|----------------------|-----------------------------------------------------------|------------------|----------------------|-------------------------------------------|
| <b>Preparación</b>   | Auditoría de brecha (gap analysis) con consultora externa | Q4 2026          | 2 semanas            | Consultora externa + Oficial de Seguridad |
| <b>Preparación</b>   | Cierre de brechas identificadas                           | Q1 2027          | 3 meses              | OTI + Oficial de Seguridad                |
| <b>Preparación</b>   | Micro-auditorías internas de verificación                 | Q1 2027          | Continuo             | Equipo auditor interno                    |
| <b>Etapa 1</b>       | Auditoría documental (revisión de diseño del SGSI)        | Q1 2027 (marzo)  | 2 días               | Entidad certificadora                     |
| <b>Preparación</b>   | Cierre de no conformidades de Etapa 1 (si las hubiera)    | Q2 2027          | 2 meses              | OTI + Oficial de Seguridad                |
| <b>Etapa 2</b>       | Auditoría de campo (implementación y evidencias)          | Q3 2027 (agosto) | 4 días (2 auditores) | Entidad certificadora                     |
| <b>Cierre</b>        | Cierre de no conformidades de Etapa 2                     | Q3 2027          | 1 mes                | OTI + Oficial de Seguridad                |
| <b>Certificación</b> | Emisión del certificado ISO 27001:2022                    | Q3/Q4 2027       | –                    | Entidad certificadora                     |
| <b>Vigilancia</b>    | Auditorías de vigilancia anuales                          | 2028, 2029, 2030 | 2 días cada una      | Entidad certificadora                     |

### 1.3.2. Auditoría de Etapa 1 (Revisión Documental)

- **Objetivo:** Verificar que el SGSI está correctamente diseñado y documentado conforme a ISO 27001:2022.
- **Alcance:** Revisión de todos los documentos del SGSI: contexto, política, alcance, SoA, metodología de riesgos, procedimientos operativos.
- **Duración típica:** 1-2 días con 1 auditor.
- **Posibles hallazgos:** Documentación incompleta, falta de evidencias de implementación inicial, inconsistencias en la SoA.
- **Si hay NC mayores:** No se puede pasar a Etapa 2 hasta cerrarlas.

### 1.3.3. Auditoría de Etapa 2 (Verificación en Campo)

- **Objetivo:** Verificar que el SGSI está implementado, operativo y es eficaz.
- **Alcance:** Entrevistas con personal clave, revisión de registros y evidencias (logs, actas, informes), verificación de controles técnicos y físicos.

- **Duración típica:** 3-5 días con 2 auditores (dependiendo del tamaño y complejidad de la UNCP).
- **Áreas a auditar (muestra):**
  - Rectorado/Comité de Gobierno Digital (liderazgo, revisión por la dirección).
  - Oficina del Oficial de Seguridad (gestión de riesgos, SoA, métricas).
  - OTI (gestión de accesos, operaciones, respuesta a incidentes, respaldos).
  - Una o dos facultades (aplicación de controles en el día a día).
  - Datacenter (seguridad física y ambiental).

#### 1.3.4. Emisión del Certificado

- El certificado se emite tras el cierre de todas las no conformidades mayores y la aceptación del plan de corrección de las menores.
- **Vigencia:** 3 años, con auditorías de vigilancia anuales.
- **Alcance del certificado:** Debe coincidir exactamente con el Alcance del SGSI definido en D-SGSI-02.

#### 1.3.5. Auditorías de Vigilancia (Años 2, 3 y 4)

- **Año 2 (2028):** Auditoría de vigilancia 1 (énfasis en mejora continua y cierre de hallazgos previos).
- **Año 3 (2029):** Auditoría de vigilancia 2 (muestra de controles diferente al año anterior).
- **Año 4 (2030):** Auditoría de recertificación (equivalente a Etapa 1 + Etapa 2).

### 1.4. Preparación Final (Pre-auditoría)

#### 1.4.1. Auditoría de Brecha (Gap Analysis)

Se recomienda contratar a una consultora externa (no la misma entidad certificadora) para realizar una **auditoría de brecha** en Q4-2026 que evalúe:

| Aspecto               | Qué se Revisa                                                             |
|-----------------------|---------------------------------------------------------------------------|
| <b>Documentación</b>  | £Todos los documentos requeridos por ISO 27001 existen y están completos? |
| <b>Implementación</b> | £Los controles declarados en la SoA están realmente implementados?        |
| <b>Evidencias</b>     | £Existen registros que demuestren la operación del SGSI?                  |
| <b>Personal</b>       | £El personal conoce sus roles y responsabilidades en el SGSI?             |
| <b>Riesgos</b>        | £La evaluación de riesgos es completa y está actualizada?                 |

#### 1.4.2. Cierre de Brechas

Los hallazgos de la auditoría de brecha se registran como RACs (**F-SGSI-04**) y se les asigna responsable y fecha límite. El Oficial de Seguridad realiza el seguimiento semanal hasta el cierre total.

### 1.5. Recursos Necesarios

| Concepto                                                               | Estimado (S/)     |
|------------------------------------------------------------------------|-------------------|
| Auditoría de brecha (consultora externa)                               | 25,000 – 35,000   |
| Honorarios de certificación (Etapa 1 + Etapa 2 + 3 años de vigilancia) | 100,000 – 120,000 |

| Concepto                                                                    | Estimado (S/)            |
|-----------------------------------------------------------------------------|--------------------------|
| Adecuaciones técnicas menores (derivadas de la auditoría de brecha)         | 20,000 – 50,000          |
| Capacitación adicional del personal (si se detectan brechas de competencia) | 10,000 – 20,000          |
| <b>Total</b>                                                                | <b>155,000 – 225,000</b> |

## 1.6. Riesgos Identificados para la Certificación

| Riesgo                                                     | Probabilidad | Impacto | Mitigación                                                              |
|------------------------------------------------------------|--------------|---------|-------------------------------------------------------------------------|
| Documentación incompleta en Etapa 1                        | Baja         | Alto    | Realizar auditoría de brecha previa; checklist de documentos requeridos |
| Personal no preparado para entrevistas de Etapa 2          | Media        | Alto    | Realizar simulacros de auditoría con el personal clave                  |
| Hallazgos técnicos no corregidos a tiempo                  | Media        | Medio   | Establecer un plan de acción con hitos quincenales                      |
| Cambios en la normativa peruana que afecten los requisitos | Baja         | Medio   | Monitoreo mensual del marco legal (D-SGSI-00)                           |

## 1.7. Documentos Relacionados

| Código                  | Nombre                                      |
|-------------------------|---------------------------------------------|
| D-SGSI-02               | Alcance del SGSI                            |
| D-SGSI-05               | Declaración de Aplicabilidad (SoA)          |
| P-SGSI-09               | Metodología de Auditoría Basada en Riesgos  |
| R-SGSI-04               | Programa Maestro de Auditoría               |
| INFORME-FINAL-SGSI-UNCP | Informe Final Ejecutivo del Diseño del SGSI |

**Elaborado por:** Oficial de Seguridad y Confianza Digital – UNCP